



CYBERSECURITY

KRISTOF WERLING

KWERLINGIT GMBH

FEBRUARY 1, 2026



MY DATA:

- Kristof Werling
- 31 years at HP: DevOps, Project Manager, Developer, Architect
- Owner: KwerlingIT GmbH
- Focus: Cyber Security
- ISO 27001 Lead Auditor, IT security audits, consulting & training
- Book author



KwerlingIT GmbH

kristof.werling@kwerlingit.com

<https://www.linkedin.com/in/kristof-werling/>

<https://www.kwerlingit.com>

CYBERSECURITY LECTURE

Discussion CrowdStrike & BSI reaction	Introduction – ISO 27001 NIS 2 BSI Basic Protection	ISO 27001 – Plan Day	ISO 27001 – Do Day	ISO 27001 – Check Day	ISO 27001 – Act Day	Pentesting - Offense – Open Source Tools
Penetration testing - Offence - Python	Pentesting - Defense – Open Source Tools	Pentesting - Defense - Python	AI use in ethical hacking and penetration testing	ISO 27002 Measures	NIS 2 CRA Product Liability Directive	Secure software development

Each module consists of 4 teaching units (1½ day)

EVALUATION WINTER SEMESTER 2025

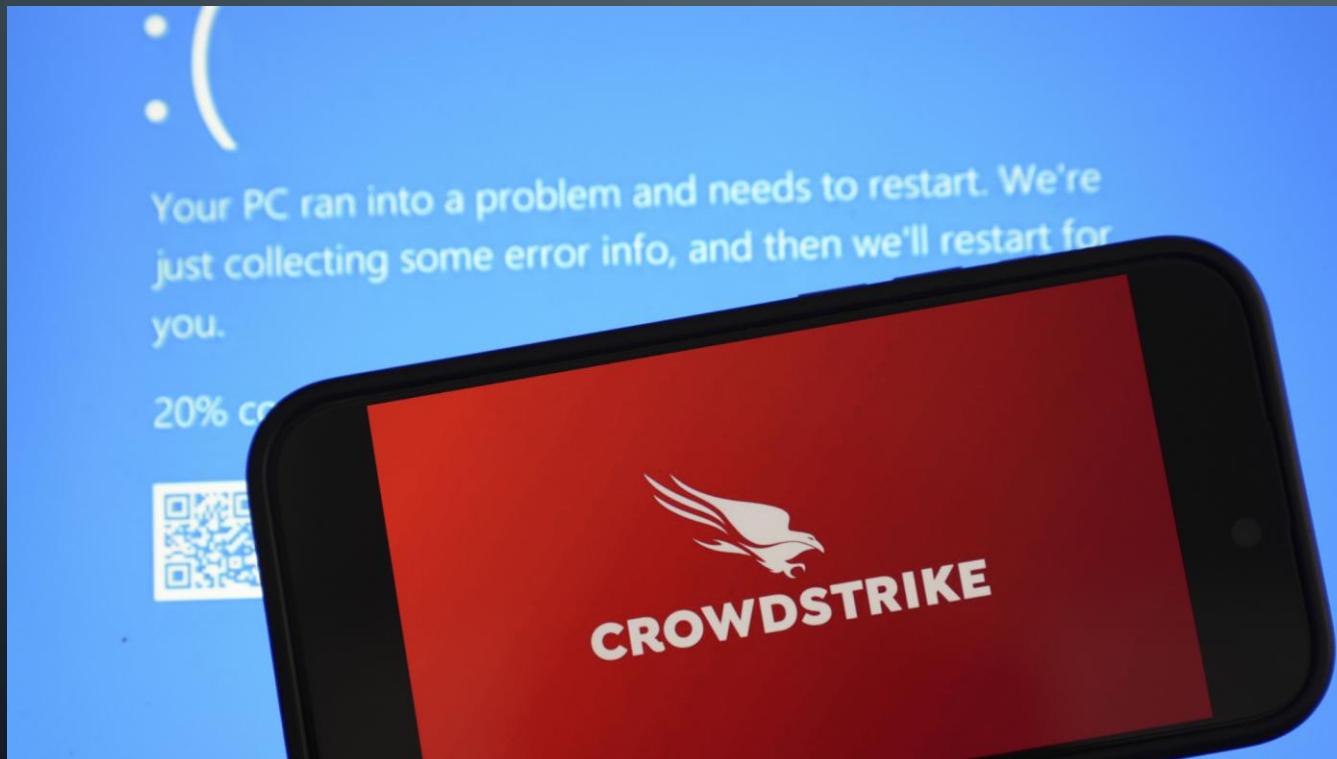


OR:

URL: <https://cloud14.evasys.de/hsrt/online/>

Password: KNE1L

CROWDSTRIKE INCIDENT



- July 19, 2024: Millions of computers worldwide display a blue screen.
- Airports, hospitals, supermarkets, television stations, banks – all at a standstill.

CROWDSTRIKE INCIDENT

- Read the iX article from September 2024: "Learning from the CrowdStrike Incident"
- You can find the document on GitHub. To clone the repository:
``git clone git@github.com:kwerling-MM/Master-Salamander-WiSe2025.git``
- Answer the questions on the next slide.

QUESTIONS & TASKS RELATED TO THE IX ARTICLE

CONSIDER THEM FROM THESE DIFFERENT PERSPECTIVES:

1. CrowdStrike
2. CrowdStrike customer (affected company)
3. CrowdStrike's customer's customer
4. IT department of CrowdStrike's client
5. IT security officer in the affected company

QUESTIONS & TASKS:

1. Outline the course of the crisis.
2. Who is responsible for which task?
3. Assess how well these requirements were met. (Explain your reasoning)
4. What was lacking?
5. What was there too much of?
6. What "homework" tasks resulted?
7. What surprised you about this crisis?

FURTHER QUESTIONS

8. How could the crisis have been prevented, either completely or partially?
9. Were data (=information) at risk during or after this crisis?
10. What preparations could have been made in advance of the crisis to
 1. to be able to react faster / better?
 2. To insure against the resulting damages? (See also: [HERE](#))

A1: OUTLINE THE COURSE OF THE CRISIS

Involved group	Sequence
CrowdStrike (CS)	July 19, 2024: Faulty update – initial customer error reports treated as isolated incidents – identified as a problem – workaround created and communicated – support team overwhelmed
Affected CS customers	BSOD across many critical systems – Unclear whether cyberattack or bug – Large parts of the IT infrastructure were down – Fix required manual effort – We had to contend with social engineering attacks
IT department of affected CS customers	Initial assumption: Cyberattack – Delayed root cause analysis – Relevant and necessary systems were down – Restart mostly not possible – Overwhelmed by the number of systems required for manual troubleshooting
IT security and data protection officers of companies	Analyzed cyberattack – data protection was paramount – the human vulnerability was unexpected.
Customers of the customers of affected companies	Emergency services, public transport including airports, even stock exchanges are out of service – no alternatives are available – information is scarce at best.

A2+3: WHO IS ASSIGNED WHICH TASK?

Involved group	Tasks)	Fulfilled?
CrowdStrike (CS)	Analyze the problem – Create a patch – Communicate and distribute it	Average: Error analysis and correction were quick. Communication wasn't fast enough.
Affected CS customers	Crisis management – keeping business processes running or restarting them – communication with IT and CS	It varied – some companies were well prepared – others had to wait for CS – often no crisis plans
IT department of affected CS customers	Error analysis – Containment of the impact – System restoration	Mixed results – unable to withstand the pressure of BSODs – overwhelmed by manual solutions – often relies on unofficial solution sources
IT security and data protection officers of companies	Data protection – defense against cyberattacks	Good – It was quickly recognized that it was a software problem – phishing and social engineering attacks had to be prevented.
Customers of the customers of affected companies	"Survive"	Difficult – No communication – Unclear situation – Unprepared

A4+5: SCARCITY & ABUNDANCE

Involved group	Shortage	abundance
CrowdStrike (CS)	Rapid crisis communication	Internal & External Support Requests
Affected CS customers	Crisis plans & redundant infrastructure	Overwhelming information overload
IT department of affected CS customers	Functioning systems	Improvised troubleshooting
IT security and data protection officers of companies	MA Awareness	Suspected cyberattack – wasted time
Customers of the customers of affected companies	Communication – flow of information to them	Confusion & Uncertainty

A6: HOMEWORK

Involved group	homework
CrowdStrike (CS)	Improved quality assurance – Better & faster crisis communication plan – More support resources
Affected CS customers	Redundant & available infrastructure – crisis management plan – communication training
IT department of affected CS customers	Emergency systems – Better & faster analysis capabilities – Increased infrastructure automation
IT security and data protection officers of companies	Improved awareness training – Improved safety strategy – Better response strategy
Customers of the customers of affected companies	?

A7: SURPRISES

Involved group	Surprises
CrowdStrike (CS)	Extent (-) – Support requests (-) – Quick workaround (+) – Communication (-)
Affected CS customers	Dependence on CS (-) – Slow communication (-) – Employee cohesion and cooperation (+)
IT department of affected CS customers	Helpless against BSDO (-) – Lengthy error handling (-) – (Quick) identification of the error source (+)
IT security and data protection officers of companies	No cyberattack (-) – Defended against social engineering attacks (-) – Identified vulnerabilities (+)
Customers of the customers of affected companies	Unexpected service outages (-) – Fraudulent attempts (-)

A8: CRISIS PREVENTION

Involved group	Measures
CrowdStrike (CS)	Testing before updates – Improved quality assurance – Early warning system for (test) customers – Rollback strategy
Affected CS customers	Redundant IT infrastructure – Redundant IT security solutions – Possibly cloud solutions as backup
IT department of affected CS customers	Emergency access options – (early) warning system for security solutions
IT security and data protection officers of companies	Security review of updates – More comprehensive awareness training
Customers of the customers of affected companies	?

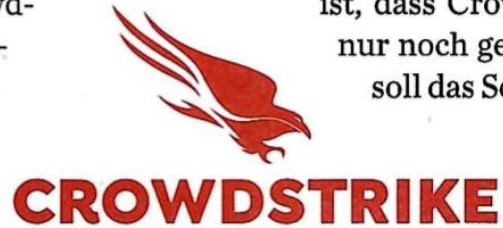
A9+10: DATA AT RISK & PREPARATION

Involved group	What data was/is at risk?
CrowdStrike (CS)	Customer data – directly or indirectly
Affected CS customers	Business, access & configuration, customer communication data
IT department of affected CS customers	Access data, configuration data, network information
IT security and data protection officers of companies	Security log data, compliance documentation
Customers of the customers of affected companies	?

BSI REACTION (I'X SEPTEMBER 2024, P. 31)

Oberste Sicherheitsbehörde reagiert auf CrowdStrike-Vorfall

■ Das Bundesamt für Sicherheit in der Informationstechnik (BSI) will Konsequenzen aus dem globalen IT-Ausfall ziehen, der sich im Juli 2024 aufgrund eines fehlerhaften CrowdStrike-Updates ereignete. Ziel des BSI ist dabei, durch geeignete Maßnahmen eine Wiederholung



auszuschließen. Dazu führte die oberste deutsche Sicherheitsbehörde Gespräche mit CrowdStrike, aber auch mit Microsoft. Eine vom BSI geforderte Maßnahme ist, dass CrowdStrike kritische Updates nur noch gestaffelt ausspielen soll. Das soll das Schadenspotenzial eines Vorfalls reduzieren. Mittelfristige Maßnahmen sollen die Gesamtarchitektur

der Produktlandschaft verbessern, etwa indem die CrowdStrike-Produkte gehärtet werden sollen. Die Behörde beabsichtigt, die Erkenntnisse aus dem Vorfall, der 8,5 Millionen Rechner weltweit betraf, bei der Implementierung des Cyber Resilience Act (CRA) zu berücksichtigen. Das BSI soll die Aufsichtsbehörde für den CRA sein, der schrittweise bis 2027 in Kraft treten soll. *Tobias Haar* (ur@ix.de)

1. Evaluate the BSI's plans. Provide a critical assessment.
2. What advantages and disadvantages do you see in this approach? ([CrowdStrike Competitors](#))

BSI REACTION (I'X SEPTEMBER 2024, P. 31)

Top security authority reacts to CrowdStrike incident

■ The Federal Office for Information Security (BSI) intends to draw consequences from the global IT outage that occurred in July 2024 due to a faulty CrowdStrike update. The BSI's goal is to prevent a recurrence



CROWDSTRIKE the overall architecture

through appropriate measures. To this end, Germany's top security authority held talks with CrowdStrike, as well as with Microsoft. One measure demanded by the BSI is that CrowdStrike should only deploy critical updates in stages. This is intended to reduce the potential damage from an incident.

Medium-term measures should

improve the product landscape, for example by hardening CrowdStrike products. The agency intends to take the findings from the incident, which affected 8.5 million computers worldwide, into account when implementing the Cyber Resilience Act (CRA). The BSI is to be the supervisory authority for the CRA, which is to come into force gradually by 2027. Tobias Haar (ur@ix.de)

1. Evaluate the BSI's plans. Provide a critical assessment.
2. What advantages and disadvantages do you see in this approach? ([CrowdStrike Competitors](#))

BSI FEEDBACK RESPONSE

Involved group	Positive	Negative
CrowdStrike (CS)	Staggered updates (no global outage) – Hardened infrastructure (improved security)	Update delays – Customer selection (test) selection – Costly implementation
Affected CS customers	Better protection against failures – Increased security through CRA	Delay of important updates – CRA compliance
IT department of affected CS customers	Stabilized Environments – Standards & Guidelines (not included in the article - CRA)	Bureaucratic
IT security and data protection officers of companies	CRA – Binding Standard – More Safety and Stability	Compliance effort – Delay in security measures
Customers of the customers of affected companies	Increased security	Higher costs and (due to delays) potentially longer downtime until the fault is rectified.

BSI FEEDBACK RESPONSE

Further considerations:

- Individual response to a general problem
(No other company is held accountable)
- The criteria for when the BSI intervenes are unclear.
- No approach to improving the protection/resilience of the affected companies
- Consequences of non-compliance unclear – a paper tiger?
- Affected end customers (or travelers) are not being considered.

WHAT WAS IT, ACTUALLY?

**Information
security
incident**

**IT security
incident**

**Cybersecurity
incident**

WHAT WAS IT, ACTUALLY?

category	assessment	Reason
Information security incident	Yes, partly	The outage affected availability – one of the three protection goals of information security (confidentiality, integrity, availability). The affected companies were unable to use their systems, which is business-critical.
IT security incident	Yes	IT security encompasses the protection of IT systems against threats. Since a faulty CrowdStrike update directly affected the stability of millions of end devices, it was clearly an IT security incident.
Cybersecurity incident	No, in the narrower sense.	Cybersecurity is usually associated with external attacks or malicious activities (malware, hacking, ransomware). The CrowdStrike incident was not an attack, but rather an internal software error during the update process. Therefore, it is more of an IT security and information security issue, not a classic cyberattack.

ONE YEAR LATER

- Read the article "One year later: Lessons from the CrowdStrike disaster", iX September 2025.
- Take a critical stance on this.

REACTIONS

reaction	Positive	Negative			Summary	
Technically	- CS: Workaround after a short time - Microsoft has restricted kernel privileges. - Roll out in stages	- These are all reactive measures. - Neither Microsoft nor CS had tested such a case. - SPoF in many organizations			Technically, the response was swift, but the learning and preparation were too late.	
Organizationally	- Improvement of crisis plans and awareness training - The BSI also actively intervened.	Implementation is usually only possible in large companies.			There was a lot of thinking, but little learning.	
Structural / Systemic	- Discussion about software monopolies and monoculture risks - Concentration risk		OS	Server	Endgeräte	The world has remained almost unchanged after CrowdStrike. Very little learning effect.
			Windows	70 – 80 %	> 90 %	
			Andere	< 30 %	< 10 %	